

Manual 25 — Implementación Controlada de Gestión de Continuidad del Negocio ISO 22301

Traducción de proyecto es-419 — no oficial.

01. Propósito, alcance y límite de uso controlado

Establezca un modelo práctico de implementación del SGContinuidad sin reproducir texto normativo de ISO ni implicar certificación, cumplimiento legal u opinión de auditoría.

02. Jerarquía de fuentes y control de versiones

Mantenga un registro de fuentes que separe ISO 22301:2019, la Enmienda 1:2024, la orientación de ISO 22313, políticas internas, requisitos contractuales, capas regulatorias y material de vigilancia de cambios.

03. Contexto de la organización

Identifique cuestiones internas y externas que afecten la capacidad de continuidad, incluidas dependencias, entorno operativo, partes interesadas, contexto relacionado con el clima cuando corresponda y restricciones estratégicas.

04. Partes interesadas y obligaciones

Mantenga un inventario controlado de expectativas de continuidad de clientes, reguladores, contratos, fuerza laboral, proveedores y sector público, con responsables y evidencia.

05. Alcance y límites del sistema de gestión de continuidad

Defina unidades organizativas, servicios, sitios, tecnologías, proveedores, datos, instalaciones y exclusiones dentro del límite del sistema de gestión de continuidad del negocio.

06. Liderazgo y rendición de cuentas

Asigne patrocinio ejecutivo, propiedad de políticas, derechos de decisión, autoridad de escalamiento, responsabilidad de financiamiento y responsabilidad sobre evidencia.

07. Política de continuidad del negocio

Mantenga una política aprobada alineada con objetivos organizacionales, alcance, obligaciones, expectativas de resiliencia y compromisos de mejora continua.

08. Roles, responsabilidades y competencia

Defina roles responsables para continuidad del negocio, liderazgo de crisis, propietarios de servicios, recuperación tecnológica, instalaciones, comunicaciones, asuntos jurídicos, RR. HH., compras y aseguramiento.

09. Planificación de riesgos y oportunidades

Identifique riesgos y oportunidades a nivel del sistema de gestión que puedan afectar sus resultados previstos y defina tratamientos con seguimiento.

10. Gobernanza del análisis de impacto al negocio

Establezca metodología de BIA, cadencia de revisión, controles de calidad de datos, autoridad de aprobación y vinculación con inventarios de servicios y estrategias de recuperación.

11. Productos y servicios críticos

Identifique productos, servicios, actividades y flujos de valor prioritarios, incluidos tolerancias aceptables de interrupción e impactos sobre partes interesadas.

12. Criterios de impacto y dimensiones temporales

Defina criterios financieros, jurídicos, de seguridad, clientes, operación, regulación, reputación y misión a través de intervalos temporales de interrupción.

13. Dependencias y requisitos de recursos

Mapee personas, instalaciones, tecnología, datos, servicios públicos, proveedores, logística, comunicaciones y dependencias especializadas necesarias para actividades prioritarias.

14. Evaluación de riesgos de interrupción

Evalúe escenarios de interrupción, vulnerabilidades, puntos únicos de falla, riesgo de concentración, exposición geográfica, dependencias cibernéticas/físicas y efectos en cascada.

15. Selección de estrategias de continuidad

Seleccione estrategias proporcionales basadas en resultados de BIA y riesgos, equilibrando resiliencia, capacidad de recuperación, costo, complejidad y riesgo residual.

16. Continuidad de personas y fuerza laboral

Defina alternativas de dotación, sucesión, capacitación cruzada, capacidad de trabajo remoto, bienestar, viajes, acceso, seguridad y controles de comunicación con la fuerza laboral.

17. Instalaciones y resiliencia física

Aborde espacios alternos de trabajo, servicios públicos, controles ambientales, seguridad física, acceso a sitios, diversificación geográfica y dependencias de recuperación de instalaciones.

18. Integración de recuperación tecnológica y cibernética

Integre objetivos de continuidad con recuperación ante desastres, respaldos, restauración, respuesta a incidentes cibernéticos, recuperación de identidades, resiliencia de infraestructura y dependencias de aplicaciones.

19. Continuidad de información y datos

Proteja disponibilidad, integridad, recuperabilidad, retención, confidencialidad y acceso controlado a la información requerida durante la interrupción y recuperación.

20. Continuidad de terceros y cadena de suministro

Defina requisitos de continuidad para proveedores, debida diligencia, evidencia, revisión de riesgo de concentración, abastecimiento alternativo, escalamiento, cláusulas contractuales y reevaluación.

21. Estructura de gestión de crisis

Defina roles estratégicos, tácticos y operativos de crisis, criterios de activación, estructura de mando, registro de decisiones, transferencias y escalamiento ejecutivo.

22. Procedimientos de respuesta a incidentes y continuidad

Mantenga procedimientos utilizables para activación, estabilización, continuidad, recuperación, escalamiento, coordinación de recursos y desactivación.

23. Comunicaciones y gestión de partes interesadas

Defina comunicaciones internas y externas, autoridad del vocero, aprobación de mensajes, notificaciones a reguladores/clientes, mantenimiento de contactos y control de rumores.

24. Objetivos de recuperación y prioridades de restauración

Traduzca tolerancias empresariales aprobadas en objetivos operativos de recuperación, secuenciación, necesidades mínimas de recursos y prioridades validadas de restauración de servicios.

25. Documentación y accesibilidad de planes

Asegure que los planes estén vigentes, controlados, disponibles bajo condiciones degradadas, adecuadamente protegidos, versionados y sean comprensibles para sus usuarios previstos.

26. Capacitación y concientización

Implemente concientización por roles, desarrollo de competencias, incorporación, capacitación de actualización, preparación de liderazgo de crisis y evidencia de finalización.

27. Programa de ejercicios y pruebas

Mantenga un programa basado en riesgo que use recorridos, simulaciones, pruebas técnicas de recuperación, ejercicios con proveedores, ejercicios de crisis y escenarios integrados.

28. Hallazgos de ejercicios y remediación

Registre observaciones, causas raíz, responsables de acciones, fechas objetivo, riesgo residual, requisitos de reprobación y evidencia de cierre para hallazgos de ejercicios e incidentes.

29. Monitoreo, medición y métricas

Defina indicadores para preparación, vigencia de planes, desempeño de recuperación, efectividad de ejercicios, resiliencia de proveedores, antigüedad de problemas y logro de objetivos.

30. Auditoría interna y aseguramiento

Planifique aseguramiento independiente y basado en evidencia sobre diseño y operación del sistema de gestión, preservando competencia del auditor, alcance, muestreo, hallazgos y límites de seguimiento.

31. Revisión por la dirección y mejora continua

Proporcione al liderazgo evidencia sobre desempeño, cambios, incidentes, ejercicios, resultados de auditoría, riesgos, recursos, objetivos y acciones de mejora.

32. Publicación, evidencia y hoja de ruta de implementación

Empaquete una hoja de ruta de implementación Esencial / Estructurada / Mejorada con verificación de fuentes, mapeo de controles/evidencia, seguimiento de problemas, localización, accesibilidad, procedencia, checksum, seguridad de workflows y compuertas de publicación. Revalide el estado de las fuentes ISO inmediatamente antes de publicar y trate ISO/CD 22301 e ISO/AWI 22313 como vigilancia de cambios no normativa mientras no se publiquen formalmente.